

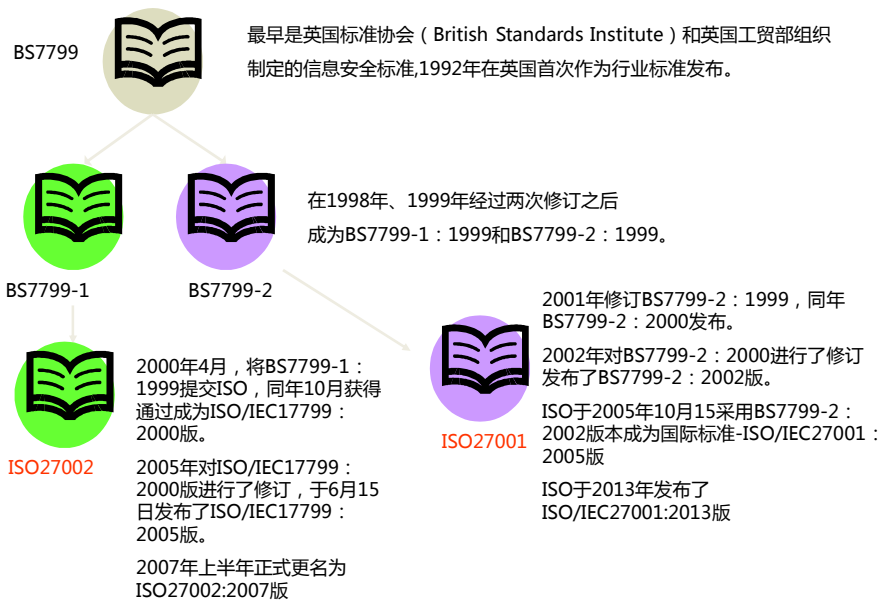
信息安全管理标准解析 (ISO27001体系)

内容目录

- ISO27000标准概述
- ISO27001 : 2013正文解析
- ISO27001 : 2013附录A解析

ISO27000体系标准概述

发展历史



ISO27000体系标准集

◆ ISO27000体系标准是由一系列标准集组成.

- 27000-27009预留给ISMS基本标准
- 27010-27019预留给ISMS行业标准
- 27031之后开始制定控制与服务的相关标准

序号	ISO/IEC标准号	标准名称	当前状态	序号	ISO/IEC标准号	标准名称	当前状态
1	ISO/IEC27000	ISMS概述和词汇	制定中	9	ISO/IEC27008	ISMS控制措施审核指南	制定中
2	ISO/IEC27001	ISMS要求	2005.10.15发布	10	ISO/IEC27009	信息安全治理框架	新项目
3	ISO/IEC27002	信息安全使用规则	2005.06.15发布	11	ISO/IEC27010	跨部门信息交换中的信息安全-管理	新项目
4	ISO/IEC27003	ISMS实施指南	制定中	12	ISO/IEC27011	通信业ISMS	2008年发布
5	ISO/IEC27004	ISMS测量	制定中	13	ISO/IEC27012	金融和保险业ISMS	制定中
6	ISO/IEC27005	信息安全风险管理	2008.06.15发布	14	ISO/IEC27013	E-GOV ISMS	新项目
7	ISO/IEC27006	ISMS认证机构要求	2007.03.15发布	15	ISO/IEC27014	服务业ISMS	新项目
8	ISO/IEC27007	ISMS审核指南	制定中				

ISO27000标准简介

◆ ISO27000 概述与词汇

- 2009年5月1日发布.它规定了ISMS标准族所共用的基本原则,概念和词汇
- 主要基于ISO13335-1:2004的第一部分:信息与通信技术安全管理概念和模型

◆ ISO27001:2013 :

- 规定了一个组织建立/实施/运行/监视/评审/保持/改进信息安全管理体系的要求;
- 基于“风险管理”思想,旨在通过持续改进的过程使组织达到有效的信息安全.
- ISO27001是用于ISMS认证和审核的标准.
- 该标准与ISO27002共同使用,一个组织在按照该标准实施ISMS的过程中,应首先选择ISO27002中推荐的控制措施.

◆ ISO27002:2007 :

- 是实施ISO27001的支撑标准,给出了组织建设ISMS时候应选择实施的控制目标和控制措施集
- 是一个信息安全最佳实践的汇总集,而不是一个认证和审核标准.

ISO27000标准简介

◆ ISO27003 实施指南

- 提供了ISO27001具体实施的指南,包括PDCA的详细指导和帮助.
- 主要基于ISO24743:2004的附录B.
- 目前为工作草案阶段.

◆ ISO27004 安全管理测量

- 提供了测量组织ISMS有效性,过程有效性和控制措施有效性的过程和方法.
- 基于ISO4742:2005
- 目前为工作草案阶段.

◆ ISO27005:2008 信息安全风险管理

- 2008年6月发布实施, 基于ISO13335-2:2005.
- 提供了风险管理的一般过程以及每个过程的详细内容.包括风险分析,风险评价,风险处置,风险接受,风险沟通,风险监视与评审等内容.

ISO27000标准简介

◆ ISO27006 对认证审核机构的要求

- 2007年3月1日发布
- 基于EA-7/03<信息安全管理体系认证/注册机构的认可指南>修订版
- 规定了第三方ISMS认证/注册机构应该满足的一般要求.

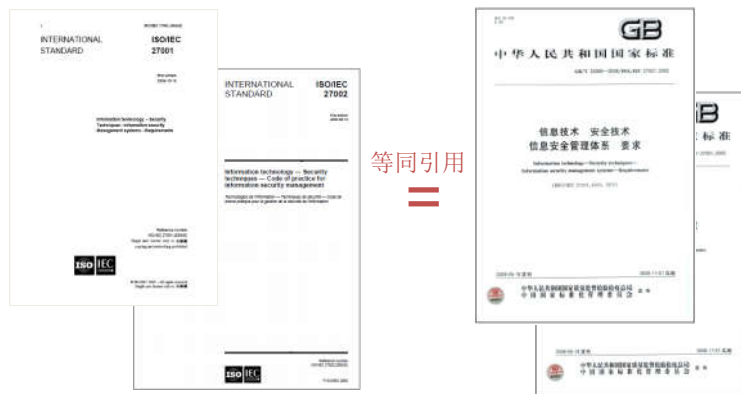
◆ ISO27007 体系审核指南

- 对信息安全管理体系及审核方法的研究, 提出了信息安全管理体系审核的指南.
- 该提案由我国2007年向ISO提出. 目前为工作草案阶段.

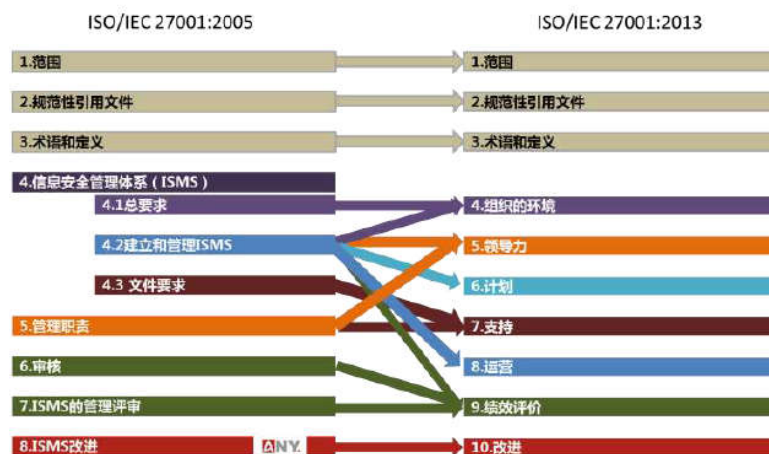
ISO27000与国标GB/T映射关系

- ◆ ISO27001:2013信息技术安全技术 信息安全管理体系规范
- ◆ ISO27002:2007信息技术安全技术 信息安全管理体系实施指南

- ◆ GB/T 22080-2008信息技术安全技术 信息安全管理体系要求
- ◆ GB/T 22081-2008信息技术安全技术 信息安全管理体系实施指南

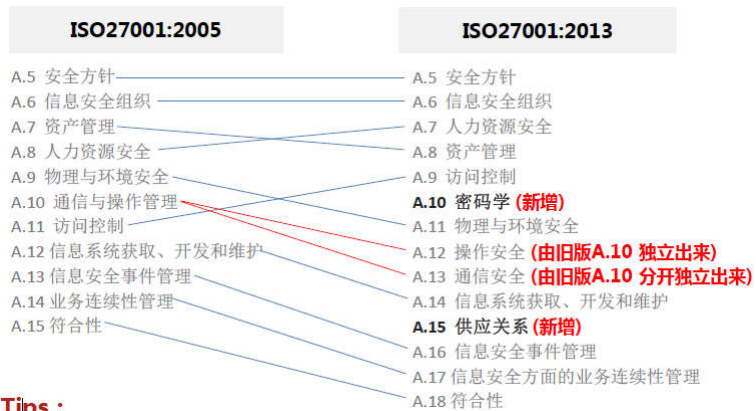


ISO27001 2005 与2013版区别



新版本采用了ISO导则73做为结构性要求，从8个章节拓展到了10个章节，重新构建了ISO标准PDCA的章节架构，这个结构在已发布的ISO22301中已经进行了应用，未来将在ISO其他标准改版中被普遍采用（包括即将改版的ISO9001 ISO20000等）

ISO27001 2005 与2013版区别



Tips :

新版标准附录A从原有11个控制域扩展为14个控制域

密码学和供应商管理成为独立的控制域

通信与操作安全管理被拆分为操作安全和通信安全

ISO27001 : 2013正文解析

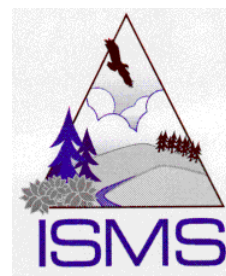
ISO27001:2013标准解析

- ◆ 解释标准的作用和所用的定义
- ◆ 解释相关术语
- ◆ 解释建立和维护文档化的ISMS的要求
- ◆ 列举可用的控制和控制目标
- ◆ 是第三方审核认证机构依照标准对组织的ISMS进行评估认证的基础



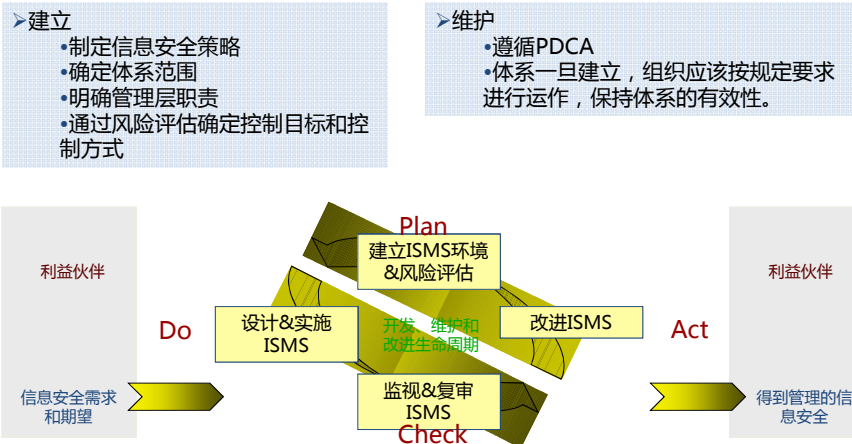
ISO27001:2013标准解析

- ◆ 解释标准的作用和所用的定义及相关术语
 - 什么是信息安全管理体系(ISMS)?
 - 标准对信息安全管理体系并没有一个十分明确的定义，它将其理解为组织管理体系的一部分。
 - ISMS是在信息安全方面指导和控制组织用以实现信息安全目标的相互关联和相关作用的一组要素。
 - 这组要素通常包括：
 - ✓ 信息安全组织结构
 - ✓ 各种活动和过程
 - ✓ 信息安全管理体系文件
 - ✓ 信息安全控制措施
 - ✓ 人力物力等资源
 - ✓
 - 什么是SoA (Statement of Applicability)
 - 什么是信息安全事件?



ISO27001:2013标准解析

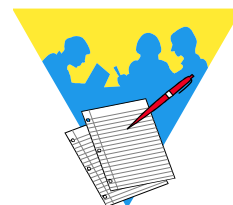
◆ 解释标准要求的ISMS建立和维护过程



ISO27001:2013标准解析

◆ 解释建立和维护文档化的ISMS的要求

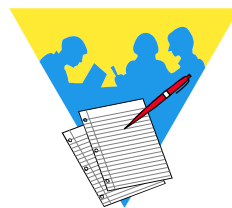
- ISMS应形成一定的文档，包括策略、适用性声明文件和实施安全控制所需的程序文件。
- 一个文档化的ISMS应该阐述：要保护的资产，组织进行风险管理的途径，控制目标和控制方式，需要的安全保障程度。
- ISMS文件体系应是分层次的.可以根据组织机构/部门职责和工作内容进行分类和分层.



ISO27001:2013标准解析

◆ 解释支撑ISMS体系运行的重要活动

- 风险评估及风险处置
 - 资产分级分类
 - 风险评估活动
 - 风险处置
- ISMS内部审核
- 纠正措施及报告
- 预防措施及报告
- ISMS管理评审
- 持续改进
- 宣贯培训



ISO27001:2013标准解析

ISO27001:2013	ISO27001:2013	ISO27001:2013
0 引言 0.1 总则 0.2 与其他管理体系的兼容性 1 适用范围 2 规范引用 3 术语和定义 4 组织背景 4.1 了解组织现状及背景 4.2 理解相关方的需求和期望 4.3 确定ISMS的范围 4.4 ISMS 5 领导力 5.1 领导力和承诺 5.2 方针 5.3 角色，责任和承诺	6 计划 6.1 处理风险和机遇的行动 6.2 可实现的信息安全目标和计划 7 支持 7.1 资源 7.2 能力 7.3 意识 7.4 沟通 7.5 文档化信息 8 运行 8.1 运行计划及控制 8.2 信息安全风险评估 8.3 信息安全风险处置	9 绩效评价 9.1 监控，度量，分析和评价 9.2 内部审核 9.3 管理评审 10 改进 10.1 不符合及纠正措施 10.2 持续改进 附录A 控制目标和控制

ISO27001:2013标准解析

章节4 组织的背景

◆ 条款4.1了解组织现状及背景

组织应明确与信息安全管理体系目的及影响其能力有关的内外部问题，以达到信息安全管理体系的预期效果。

◆ 条款4.2 理解相关方的需求和期望

组织应确定：

- a) 信息安全管理体系的相关方;
- b) 这些相关方信息安全相关要求



ISO27001:2013标准解析

◆ 条款4.3 理解相关方的需求和期望

确定ISMS 的范围

组织应确定信息安全管理体系的边界和适用性，以确定其范围。

在确定此范围时，组织应考虑：

- a) 4.1 提及的外部和本部的问题;
- b) 4.2 提及的要求;
- c) 接口和执行组织之间活动的依赖关系，以及其他组织的相关活动。

ISMS范围应可成为文档化信息。

◆ 条款4.4 ISMS

组织应按照本国际标准的要求建立，实施，保持和持续改进信息安全管理体系

ISO27001:2013标准解析

章节5 领导力

◆ 条款 5.1 领导力和承诺

最高管理者应表现出对信息安全管理体的领导力和承诺：

- a) 确保信息安全策略和信息安全目标的制定，并与组织的战略方向兼容；
- b) 确保信息安全管理体系的要求整合到组织的过程中；
- c) 确保信息安全管理体系所需要的资源；
- d) 传达有效的信息安全管理的重要性，并符合信息安全管理体系的要求；
- e) 确保信息安全管理体系达到其预期的效果；
- f) 指导和支持员工对信息安全管理体系作出有效的贡献；
- g) 促进持续改进；
- h) 支持其他相关管理角色来展示自己的领导力，因为它适用于他们的职责范围。

ISO27001:2013标准解析

◆ 条款 5.2 方针

最高管理者应建立一个信息安全方针：

- a) 与组织的宗旨相适应；
- b) 包括信息安全目标（见 6.2），或为信息安全目标提供框架；
- c) 包括满足与信息安全相关要求的承诺；
- d) 包括信息安全管理体系持续改进的承诺。

信息安全的方针应：

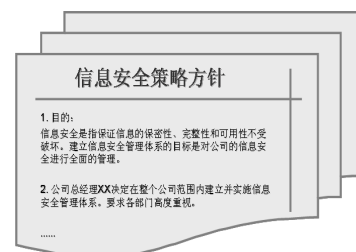
- e) 可成为文档化信息；
- f) 在组织内沟通；
- g) 视情况提供给相关方。

◆ 条款5.3 角色，责任和承诺

最高管理者应确保与信息安全相关角色的职责和权限的分配和沟通。

最高管理者应指定责任和权限：

- a) 确保信息安全管理体系符合本国际标准的要求；
- b) 将 ISMS 的绩效报告给最高管理者。



ISO27001:2013标准解析

章节 6 计划

◆ 条款 6.1 处理风险和机遇的行动

6.1.1 总则

当规划组织的信息安全管理体系时，应当考虑 4.1 提到的问题和 4.2 中所提到的要求，并确定需要解决的风险和机遇：

- a) 确保信息安全管理体系可实现预期的结果;
- b) 防止或减少不良影响;
- c) 实现持续改进。

组织应策划：

- d) 解决这些风险和机遇的措施；
- e) 如何
 - 1) 整合和实施这些措施，并纳入其信息安全管理体系过程中;
 - 2) 评估这些措施的有效性。

ISO27001:2013标准解析

◆ 条款 6.1 处理风险和机遇的行动

6.1.2 信息安全风险评估

组织应确定信息安全风险评估过程：

- a) 建立和维护信息安全风险的标准，包括风险接受准则;
- b) 决定执行的信息安全风险评估的标准;
- c) 确保重复使用信息安全风险评估过程能产生一致的，有效的和可比较的结果。

组织应：

- d) 识别信息安全的风险。
 - 1) 应用信息安全风险评估过程，以识别 ISMS 范围内的信息保密性，完整性和可用性的损失风险。
 - 2) 识别风险的所有者。
 - e) 分析信息安全风险。
 - 1) 评估 实现后潜在的后果。
 - 2) 评估 实现的可能性。
 - 3) 确定风险等级。
 - f) 评估信息安全风险。
 - 1) 建立的风险标准比较风险分析结果，并建立优先级。
- 组织应保留的信息安全风险评估过程中的文档化信息。

ISO27001:2013标准解析

◆ 条款 6.1 处理风险和机遇的行动

6.1.3 信息安全风险处置

组织应采用信息安全风险处置过程：

- a) 选择适当的信息安全风险处理方法，考虑风险评估的结果;
- b) 确定所有实施的信息安全风险处置措施是必要的;
- c) 比较 6.1.3 b)中与附件 A 中的控制项，并确认已省略没有必要的控制项;
- d) 制作一个包含必要的控制项和包含理由的适用性声明，无论实施与否，并应包含删减附件 A 中控制项的理由;
- e) 制定信息安全风险处置计划;
- f) 风险处置方案和残余风险应得到风险负责人的批准。

组织应保留信息安全风险的处理过程中的文档化信息。

ISO27001:2013标准解析

条款 6.2 可实现的信息安全目标和计划

组织应建立相关职能和层次的信息安全目标。

信息安全目标应：

- a) 与信息安全方针一致;
- b) 是可衡量的（如果可行）;
- c) 考虑到适用的信息安全要求，以及风险评估和处置结果;
- d) 是可沟通的;
- e) 能适时更新。

组织应保留信息安全目标相关的文档化信息。

当计划如何实现信息安全目标时，组织应确定：

- f) 做什么;
- g) 需要哪些资源;
- h) 谁负责;
- i) 何时完成;
- j) 如何评估结果。

ISO27001:2013标准解析

章节 7 支持

◆ 条款 7.1 资源

组织应确定并提供信息安全管理体的建立，实施，维护和持续改进所需的资源。

◆ 条款 7.2 能力

组织应：

- a) 确定员工在 ISMS 管控下工作的必备能力，这会影响到组织的信息安全绩效;
- b) 确保这些人在适当的教育，培训或取得经验后是能胜任的;
- c) 在适当情况下，采取行动以获得必要的的能力，并评估所采取行动的有效性;
- d) 保留适当的文档化信息作为证据。

◆ 条款 7.3 意识

为组织工作的人员应了解：

- a) 信息安全方针;
- b) 他们对信息安全管理体系有效性的贡献，包括提高信息安全绩效的收益;
- c) 不符合信息安全管理体系要求所带来的影响，。

ISO27001:2013标准解析

◆ 条款 7.4 沟通

组织应确定信息安全管理体中内部和外部相关的沟通需求：

- a) 沟通什么;
- b) 何时沟通;
- c) 和谁沟通;
- d) 谁应该沟通;
- e) 怎样的沟通过程是有效的。

◆ 条款 7.5 文档化信息

7.5.1 总则

组织的信息安全管理体系应包括：

- a) 本国际标准所需要的文档化信息;
- b) 记录信息安全管理体系有效性必要的文档化信息。

7.5.2 创建和更新

- a) 当创建和更新文档化信息时，组织应确保适当的：
- b) 识别和描述（如标题，日期，作者，或参考号码）;
- c) 格式（如语言，软件版本，图形）和媒体（如纸张，电子）;
- d) 适当和足够的审查和批准

ISO27001:2013标准解析

◆ 条款 7.5 文档化信息

7.5.3 文档化信息的控制

信息安全管理体系与本国际标准要求的文档化信息应被管理，以确保：

- a) 当文档化信息被需要时是可用且适用的;
- b) 得到充分的保护（例如保密性丧失，使用不当，完整性丧失）。

对于文档化信息的控制，组织应制定以下活动（如适用）：

- c) 分配，访问，检索和使用;
- d) 存储和保存，包括易读性的保存;
- e) 变更管理（例如版本控制）;
- f) 保留和处置。

组织信息安全管理体系的规划和运作必要的外来文档化信息，应被适当识别和管理。

ISO27001:2013标准解析

章节 8 运行

◆ 条款 8.1 运行计划及控制

组织应策划，实施和控制过程需求以满足信息安全要求，并实施在 6.1 中确定措施。组织还应当实施计划，以实现信息安全在 6.2 中确定的目标。

组织应保存相关的文档化信息，以保证过程已按照计划实施。

组织应控制计划变更，同时审计非计划变更，并采取适当措施以减轻任何不良影响。

组织应确保外包过程是被确定和受控。

◆ 条款 8.2 信息安全风险评估

组织应在技术时间间隔或发生重大变化时执行信息安全风险评估，将 6.1.2 中建立的标准纳入考虑范围。

组织应保留信息安全风险评估结果的相关文档化信息。

◆ 条款 8.3 信息安全风险处置

组织应实施信息安全风险处置计划。

组织应保留信息安全风险处置结果的文档化信息。



ISO27001:2013标准解析

章节 9 绩效评价

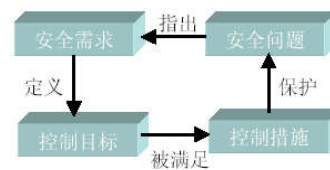
◆ 条款 9.1 监控，度量，分析和评价

组织应评估信息安全绩效和信息安全管理体系的有效性。

组织应确定：

- a) 需要进行监视和测量，包括信息安全过程和控制要求;
- b) 监测，测量，分析和评估（如适用）的方法，以确保结果有效;
- c) 监视和测量时间;
- d) 谁应监视和测量;
- e) 何时对监视和测量的结果进行分析和评估;
- f) 谁应分析和评估这些结果。

组织应保留适当的监视和测量结果的文档化信息作为证据。



ISO27001:2013标准解析

◆ 条款 9.2 内部审核

组织应在计划的时间间隔进行内部审核，根据提供的信息判断是否安全管理体系：

- a) 符合
 - 1) 组织自身信息安全管理的要求;
 - 2) 本国际标准的要求;
- b) 有效实施和保持。

组织应：

- c) 计划，建立，实施并保持审核方案，其中包括频率，方法，职责，计划要求和报告。审核程序应考虑相关过程和以往审核结果的重要性;
- d) 定义每次审核的章程和范围;
- e) 选择审核员和审核组长以确保审核过程的客观性和公正;
- f) 确保审核结果报告提交相关管理层;
- g) 保留审核程序和审核结果相关的文档化信息作为证据。

ISO27001:2013标准解析

◆ 条款9.3 管理评审

最高管理者应在计划的时间间隔评审组织的信息安全管理体系，以确保其持续的适宜性，充分性和有效性。

管理评审应考虑：

- a) 以往管理评审行动措施的状态;
- b) 与信息安全管理体系相关的内外部问题的变化;
- c) 反馈信息安全绩效和趋势，包括：
 - 1) 不符合与纠正措施;
 - 2) 监控和测量结果;
 - 3) 审核结果;
 - 4) 信息安全目标的实现;
- d) 相关方的反馈;
- e) 风险评估的结果和风险处置的状态;
- f) 持续改进的机会。

管理评审的输出应包括持续改进的机会和任何信息安全管理体系需要变更的相关决定。

组织应保留管理评审结果的文档化信息作为证据。

ISO27001:2013标准解析

章节10 改进

◆ 条款 10.1 不符合及纠正措施

出现不符合时，组织应：

- a) 对不符合作出反应，如适用：
 - 1) 采取行动控制和纠正;
 - 2) 处理结果;
- b) 评估采取措施的必要性，以消除不符合的原因，使不复发或不在其他地方发生，通过：
 - 1) 审查不符合;
 - 2) 确定不符合的原因;
 - 3) 确定是否存在类似的不符合和发生的可能;
- c) 实施所需的任何措施;
- d) 审查已采取纠正措施的有效性;
- e) 如果有必要的话，改进信息安全管理体系。

纠正措施应对不符合产生适当的影响。

组织应保留以下文档化信息作为证据：

- f) 不符合的性质和后续措施;
- g) 任何纠正措施的结果。

◆ 条款 10.2 持续改进

组织应不断提高信息安全管理体系的适宜性，充分性和有效性。

ISO27001体系文件架构

◆ ISMS文件体系应该是分层次的, 如下:

- 对管理框架的概括(一级文件)
 - ✓ 包括策略、控制目标、已实施的控制措施、适用性声明 (SOA)
- 各种程序文件(二三级文件)
 - ✓ 实施控制措施并描述责任和活动的程序文件
 - ✓ 覆盖了ISMS管理和运行的程序文件
- 证据(四级文件)
 - ✓ 能够表明组织按照ISO27001要求采取相应步骤而建立了管理框架
 - ✓ 各种Records : 在操作ISMS过程当中自然产生的证据, 可识别过程并显现符合性

ISO27001:2013附录A解析

ISO27001:2013附录A解析

◆ 14个域/114个控制项:

- 安全方针
- 信息安全组织
- 人力资源安全
- 资产管理
- 访问控制
- 密码学
- 物理和环境安全
- 操作安全
- 通信安全
- 系统获取，开发和维护
- 供应关系
- 信息安全事件管理
- 信息安全方面的业务连续性管理
- 符合性



ISO27001:2013附录A解析



ISO27001:2013附录A解析

A.5 安全方针

A.5.1 信息安全管理方向

A.5.1.1 信息安全方针

A.5.1.2 信息安全方针的评审

目标：为信息安全提供与业务需求和法律法规相一致的管理指示及支持。

◆策略方针的目的和意义

- 为组织提供了关注的焦点，指明了方向，确定了目标
- 确保信息安全管理体系被充分理解和贯彻实施
- 统领整个信息安全管理体系

◆信息安全策略的定义

- 信息安全策略（或者方针）是由组织的最高管理者正式制订和发布的信息安全目标和方向，用于指导信息安全管理体系的建立和实施过程。

ISO27001:2013附录A解析

◆方针策略文件的内容

- 信息安全的定义、整体目标和范围；
- 对管理层支持信息安全目标和原则的意图的声明和承诺；
- 建立控制目标和控制的框架，包括风险评估和风险管理的框架；
- 对安全策略、原则、标准以及符合性需求的简单说明；
- 对策略支持文档的引用参考；
- 由管理者批准，正式发布，并得到全员贯彻。

◆安全策略的复查

- 策略应有一个属主，负责按复查程序维护和复查该策略。
- 如果发生任何影响最初风险评估基础的变化，都应复查策略。也应定期复查安全策略。
- 策略复审应该考虑到管理评审的结果

◆ <安全策略>编写要点:

- 用最简单、明确的语言直击主题
- 保持与具体规范、指南、记录等文件的区别
- 信息安全策略应该人手一份，并保证充分理解
- 要定期评审和修订



<安全策略> 示例:

INFORMATION SECURITY POLICY STATEMENT

- All managers are directly responsible for implementing the policy and ensuring staff compliance in their respective departments.
- Compliance with the Information Security Policy is mandatory.

Signature: _____ Date: _____
Title: _____

The policy will be reviewed yearly by the Information Security Manager.

INFORMATION SECURITY POLICY STATEMENT

The following is a sample information security policy statement.

OBJECTIVE

The objective of information security is to ensure the business continuity of **Organization X** and to minimize the risk of damage by preventing security incidents and reducing their potential impact.

POLICY

- The policy's goal is to protect the organization's informational assets¹ against all internal, external, deliberate or accidental threats.
- The Chief Executive Officer must approve the information security policy.

The information security policy ensures that:

- Information will be protected against any unauthorized access;
- Confidentiality of information will be assured;
- Integrity of information will be maintained;
- Availability of information for business processes will be maintained;
- Legislative and regulatory requirements will met;
- Business continuity plans will be developed, maintained and tested²;
- Information security training will be available for all employees;

- All actual or suspected information security breaches will be reported to the Information Security Manager and will be thoroughly investigated.
- Procedures exist to support the policy, including virus control measures, passwords and continuity plans.
- Business requirements for availability of information and systems will be met.
- The Information Security Manager is responsible for maintaining the policy and providing support and advice during its implementation.

¹ Information can exist in various forms, and includes data stored on computers, transmitted over networks, printed or written on paper, sent to the cloud or otherwise in magnetic codes or discussed during telephone conversations.
² This plan allows users to access information and essential services when needed.

ISO27001:2013附录A解析

A.6 信息安全组织

A.6.1 内部组织

A.6.1.1 信息安全的角色和职责

A.6.1.2 职责分离

A.6.1.3 与监管机构的联系

A.6.1.4 与特殊利益团体的联系

A.6.1.5 项目管理中的信息安全

目标：建立一个管理框架，启动和控制组织内实施信息安全。

A.6.2 移动设备和远程办公

A.6.2.1 移动设备策略

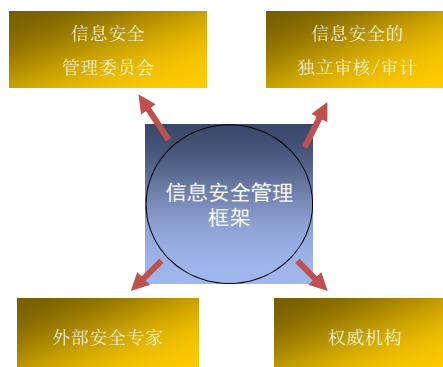
A.6.2.2 远程办公

目标：确保远程办公和移动设备使用的安全性

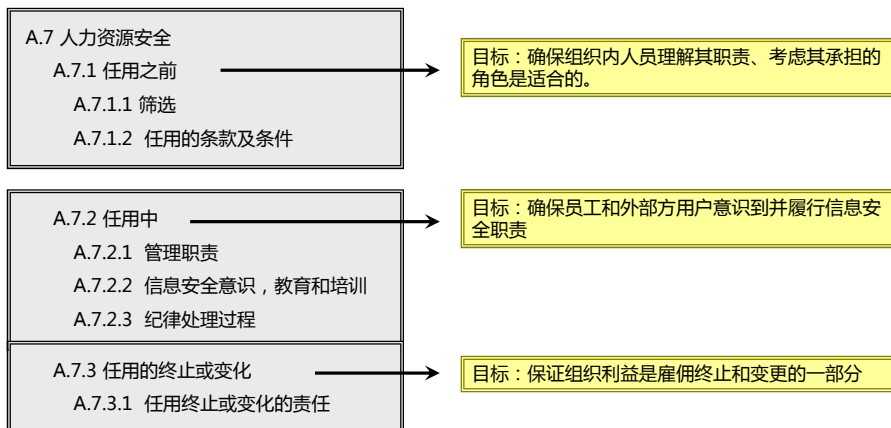
ISO27001:2013附录A解析

内部组织

组织应该建立起有效的信息安全管理框架，以便发起并控制组织内部信息安全的实施。



ISO27001:2013附录A解析



人员安全重要提示

- ◆ 人员和组织安全是信息安全管理难点，因为：
- ◆ 人本身就是一个最复杂的因素
- ◆ 信息安全的“潜在性”使得安全组织和人才培养不容易获得认可
- ◆ 信息安全人才的培养是一个高难的过程
- ◆ 信息安全组织需要和企业文化进行磨合
- ◆ 避免信息安全组织和业务组织对立



人员筛选时做背景检查

- ◆ 背景检查是工作申请过程的一个部分，组织至少会审查申请人简历中的基本信息。对于敏感职位，可能还会考虑进一步的调查。调查过程中，组织可以请求访问申请人的信用和犯罪记录，甚至可以聘请外部公司对申请人进行调查，以确定是否存在潜在问题或利益冲突。
- ◆ 通过背景检查，可以防止：
 - 因为人员解雇而导致法律诉讼
 - 因为雇用疏忽而导致第三方的法律诉讼
 - 雇用不合格的人员
 - 丧失商业秘密
- ◆ 员工从一般岗位转入信息安全重要岗位，组织也应当对其进行检查，对于处在有相当权力位置的人员，这种检查应定期进行。

增强全员的安全意识

- ◆ 安全意识（Security awareness），泛指组织员工对安全和安全控制重要性的一般性的、集体的意识。促进安全意识，可以减少人员的非授权活动，可以增强保护控制的效率，有助于避免欺诈和对计算资源的浪费
- ◆ 员工具有安全意识的标志：
 - 认知可能存在的安全问题及其危害，理解安全所需
 - 明白自身的安全职责，恪守正确的行为方式
- ◆ 促进安全意识的方法和途径多种多样：
 - 交互性的、实时的介绍，课程，视频
 - 出版发布物品，新闻传单，张贴物，简报，布告栏，Intranet
 - 奖金和赞誉等激励机制
 - 提醒物，比如登录banner，笔、便签、鼠标垫等随身物品
- ◆ 安全意识材料应该直接、简单和清楚，易于理解，要有创新和变化

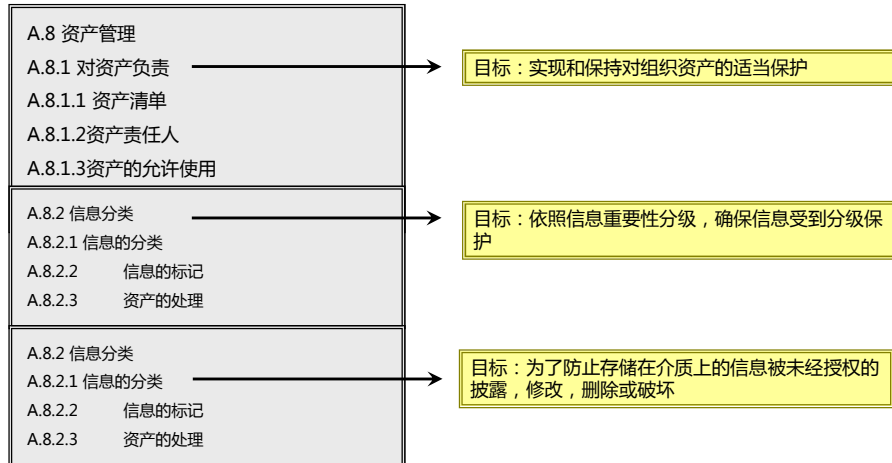
安全培训和教育

- ◆ 培训 (Training) 不同于意识，其目的是传授安全相关的工作技能，主要对象为信息系统管理和维护人员，通常利用一对一的课堂形式，包括：
 - 为操作者和具体用户提供的安全相关的职务培训
 - 为与敏感安全位置相关的具体的部门或人员提供的技能培训
 - 为IT支持人员和系统管理员提供的技术性安全培训
 - 为安全实践者和信息系统审计师提供的高级信息安全培训
 - 为高级管理者、职能经理和业务单位经理提供的安全培训
- ◆ 教育 (Education) 更为深入，其目的是为安全专业人士提供工作所需的专业技术，一般通过外部程序实现，并且应该成为职业规划的一部分
- ◆ 具体的安全软件和硬件的产品培训也很重要

加强人员离职控制

- ◆ 人员离职往往存在安全风险，特别是雇员主动辞职时
- ◆ 解雇通知应选择恰当的时机，例如重要项目结束，或新项目启动前
- ◆ 使用标准的检查列表 (Checklist) 来实施离职访谈
- ◆ 离职者需在陪同下清理个人物品
- ◆ 确保离职者返还所有的公司证章、ID、钥匙等物品
- ◆ 与此同时，立即消除离职者的访问权限，包括：
 - 解除对系统、网络和物理设施的访问权
 - 解除电话，注销电子邮箱，锁定Internet账号
 - 通知公司其他人员、外部伙伴或客户，声明此人已离职

ISO27001:2013附录A解析



信息资产的属主、保管者和用户

◆ 属主 (Owner) :

- 信息属主可能是组织的某个决策者或者管理者，或者部门负责人，或者是信息的创建者，对必须保护的信息资产负责，承担着“due care”的责任，但日常的数据保护工作则由保管者承担。信息属主的责任在于：
- 基于业务需求，对信息分类等级作出最初决定；定期复查分类方案，根据业务需求的变化作出更改；向保管者委派承担数据保护任务的责任

◆ 保管者 (Custodian) :

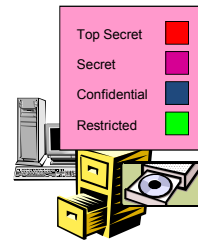
- 受信息属主委托而负责保护信息，通常由IT系统人员来承担，其职责包括：
- 定期备份，测试备份数据的有效性；必要时对数据进行恢复；根据既定的信息分类策略，维护保留下来的记录

◆ 用户 (User) :

- 任何在日常工作中使用信息的人（操作员、雇员或外部伙伴），即数据的消费者，应该注意：
- 用户必须遵守安全策略中定义的操作程序；用户必须在工作期间承担保护信息安全的责任；用户必须只将公司的计算资源用作公司目的，不能做个人使用

信息资产的分类分级

- ◆ 信息：数据库和数据文件，合同和协议，系统文件，用户手册，培训资料等
- ◆ 软件资产：应用软件，系统软件，开发工具，工具程序
- ◆ 实物资产：计算机和通信设备，移动介质，电源空调等技术性设备
- ◆ 人员：承担特定职能和责任的人员，资质、技能和经验
- ◆ 服务：计算和通信服务，环境支持服务等
- ◆ 组织形象与声誉：无形资产



识别资产时的注意事项

- ◆ 所有主要信息资产都应清点并指定专人负责
- ◆ 这些资产必须是在信息安全管理范围之内
- ◆ ISO27001标准认为，“资产”没必要包括通常考虑的组织内所有有价值的东西
- ◆ 组织必须确定哪些资产在损失后对组织的产品及服务会产生实质上的影响



ISO27001:2013附录A解析

A.9访问控制

A.9.1访问控制的业务要求

A.9.1.1访问控制策略

A.9.1.2网络服务的使用政策

目标：限制访问信息和信息处理设施

A.9.2用户访问管理

A.9.2.1用户注册和注销

A.9.2.2用户访问开通和撤销

A.9.2.3特权管理

A.9.2.4用户秘密认证信息的管理

A.9.2.5用户访问权的复查

A.9.2.6移除或调整访问权限

目标：确保授权用户访问系统和服务，并防止未授权的访问

ISO27001:2013附录A解析

A.9.3用户职责

A.9.3.1秘密认证信息的使用

目标：让用户明确身份认证信息的保护负责

A.9.4系统和应用程序的访问控制

A.9.4.1信息访问限制

A.9.4.2安全登录程序

A.9.4.3口令管理系统

A.9.4.4特权实用程序的使用

A.9.4.5程序源码的访问控制

目标：防止对系统和应用的未授权使用

访问控制重要提示

- ◆ 关于访问控制策略：
 - 根据业务制订的策略才能实施
 - 策略内容：所需访问的信息，访问控制规则，用户访问权限，其他访问控制要求
 - 没有明确允许就是缺省禁止，最小权限原则等
- ◆ 口令是常见的访问控制措施，也是重要的信息资产，应妥善保护和管理
- ◆ 关于网络访问控制：
 - 组织网络与其他组织网络或者公共网之间进行正确的连接
 - 用户和设备都具有适当的身份验证机制
 - 在用户访问信息服务时进行控制
- ◆ 关于操作系统访问控制：
 - 识别和验证来访者身份。如果需要，还要验证每个合法用户的终端节点或位置
 - 记录成功和失败的系统访问
 - 提供适当的身份验证方法。如果使用了口令管理系统，则应该确保使用高质量的口令
 - 根据情况限制用户连接时间

访问控制重要提示（续）

- ◆ 关于应用访问控制：
 - 考虑应用系统的安全，不得不考虑业务流程
 - 如果业务流程有安全隐患，应用系统是无法避免这些危险的。底层系统和网络更是无能为力
- ◆ 关于系统监控：
 - 日志、入侵监测系统、漏洞分析扫描器都是很好的工具，但是如果没有有效的审计措施的话，都无法发挥大作用
- ◆ 关于移动计算的访问控制：
 - 可变性太大
 - 有时会涉及“人格”问题、“工作热情”问题
 - 执行控制需要坚决的政策和有力的执行
 - 要关注新技术的冲击

ISO27001:2013附录A解析

A.10密码学

A.10.1密码控制

A.10.1.1加密使用控制政策

A.10.1.2密钥管理

目标：恰当和有效的利用密码学保护信息的保密性、真实性或完整性

- ◆ 在整个组织内针对使用加密控制的管理方法应遵循信息资产管理相关制度的要求进行实施；
- ◆ 组织应根据信息资产的保密性、完整性等级来确定需要的保护级别，并考虑需要的加密算法的类型、强度和质量；
- ◆ 密钥管理贯穿密钥的整个生命周期，包括密钥的生成、存储、归档、检索、分发、回收和销毁；
- ◆ 须保护所有的密钥免遭修改、丢失和毁坏。并防范对秘密密钥和私有密钥非授权的泄露。对生成、存储和归档密钥的设备进行适当的物理保护；

ISO27001:2013附录A解析

A.11物理和环境安全

A.11.1安全区域

A.11.1.1物理安全边界

A.11.1.2物理入口控制

A.11.1.3办公室，房间和设施的安全保护

A.11.1.4外部和环境威胁的安全防护

A.11.1.5在安全区域工作

A.11.1.6交付和交接区

目标：阻止对组织场所和信息的未授权屋里访问、损坏和干扰



A.11.2设备

A.11.2.1设备安置和保护

A.11.2.2支持性设备

A.11.2.3布缆安全

A.11.2.4设备维护

A.11.2.5资产的移动

A.11.2.6场外设备和资产安全

A.11.2.7设备的安全处置或再利用

A.11.2.8无人值守的用户设备

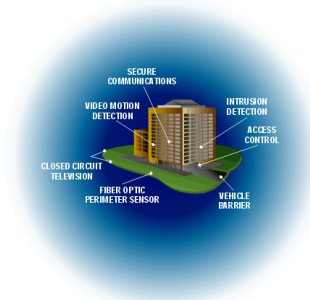
A.11.2.9清除桌面和清屏策略

目标：防止资产的丢失、损坏、失窃或危及资产安全以及组织活动的中断



物理安全要点提示

- ◆ 清晰划定安全区域边界
- ◆ 围墙、门锁、照明、告警、监视系统
- ◆ 专门设立接待区，限制物理访问
- ◆ 外来人员登记及陪同
- ◆ 定期检查访问记录
- ◆ 关键设施不要放置在公共区域
- ◆ 关键区域不做显眼标记
- ◆ 防止火灾、水灾、地震、爆炸等自然或人为灾难
- ◆ 安全区域内工作，禁止摄影摄像，加强监督
- ◆ 一定要注意那些不在视野范围内的东西



关于场外设备使用的提示

- ◆ 无论是谁，信息处理设施要带到组织边界外使用，必须得到相关授权
- ◆ 场外设备或介质不应该单独置于公共区域，笔记本电脑应该放在不显眼的包里
- ◆ 注意设备防暴、防磁、防热、防水、防震
- ◆ 家庭办公时，遵守设备加锁保存、桌面净空、计算机访问控制及安全通信策略
- ◆ 可以考虑购买适当的保险



ISO27001:2013附录A解析

A.12 操作安全

A.12.1 操作程序和职责

- A.12.1.1 文件化的操作程序
- A.12.1.2 变更管理
- A.12.1.3 容量管理
- A.12.1.4 开发，测试和运行环境的分离

目标：确保正确、安全的操作信息处理设施

A.12.2 恶意软件防护

- A.12.2.1 控制恶意软件

目标：确保信息和信息处理设施不受恶意软件侵害

A.12.3 备份

- A.12.3.1 信息备份

目标：防止数据丢失

ISO27001:2013附录A解析

A.12.4 记录和监控

- A.12.4.1 事件日志
- A.12.4.2 日志信息的保护
- A.12.4.3 管理员和操作员日志
- A.12.4.4 时钟同步

目标：记录事件并生成证据

A.12.5 操作软件的控制

- A.12.5.1 操作系统软件的安装

目标：保证操作系统的完整性

A.12.6 技术漏洞管理

- A.12.6.1 技术漏洞的管理
- A.12.6.2 限制软件安装

目标：防止利用公布的技术脆弱性导致的风险

A.12.7 信息系统审计考虑

- A.12.7.1 信息系统审计控制

目标：将业务系统审计过程的影响最小化

操作管理提示

- ◆ 明确操作管理程序和责任，包括信息处理、备份、故障处理、介质处理、系统重启和恢复、日志审计等事务
- ◆ 定义变更管理责任和流程，做好信息处理设施的变更控制
- ◆ 对第三方服务实施有效监督，确保其符合既定协议的要求。应该定期检查服务报告，分析安全事件相关信息，复查第三方审计记录
- ◆ 制定专门的策略，禁止使用非授权软件，防止恶意代码
- ◆ 做好系统的备份容灾规划
- ◆ 移动介质使用是一个管理难题，应该采取有效措施，防止信息泄漏

ISO27001:2013附录A解析

A.13通信安全

A.13.1网络安全管理

A.13.1.1网络控制

A.13.1.2网络服务的安全

A.13.1.3网络隔离

目标：确保网络中信息的安全性并保护支持性的信息处理设施

A.13.2信息传输

A.13.2.1信息传输的策略和程序

A.13.2.2信息传输协议

A.13.2.3电子消息

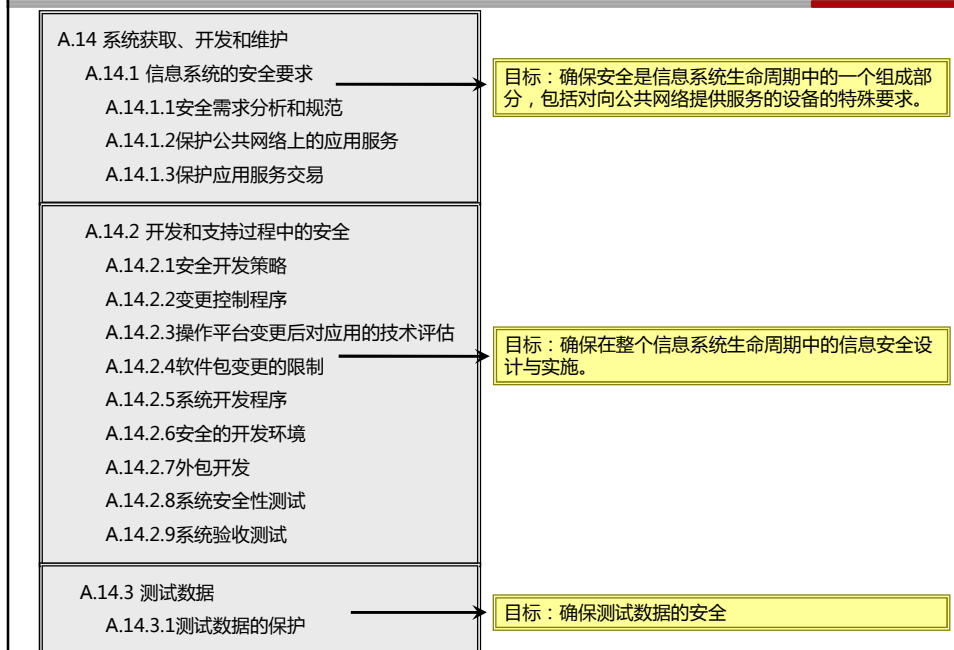
A.13.2.4保密或不泄露协议

目标：维护组织与任何外部实体的信息传输安全

网络控制提示

- ◆ 确保网络的安全、防止未授权访问所连接的服务，保护在公用网络上或无线网络上传递数据的保密性和完整性，保护已连接的系统及应用，维护所连接的网络服务和计算机的可用性；
- ◆ 公司内部网络与互联网连接时需实施足够的安全隔离保护措施；未经批准，严禁将公司网络同外部其他网络以任何形式直接连接。由于业务原因而产生第三方网络需要连接公司网络时，必须设置足够可靠的技术隔离措施。
- ◆ 所有来自非信任系统或网络（比如，外联网）对公司网络的访问，必须通过部署获批防火墙来进行控制。

ISO27001:2013附录A解析



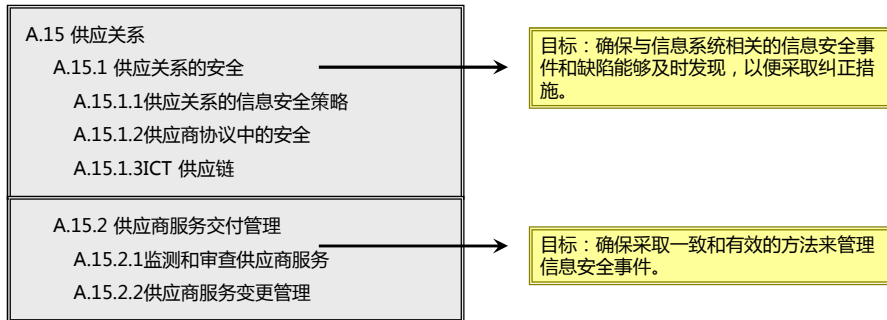
系统开发安全性的重要提示

- ◆ 建立安全的软件开发过程和编码规范
- ◆ 开发一个有关如何利用加密控制对信息进行保护的策略（哪些信息要加密，加密的强度如何，移动介质或传输中的加密，密钥管理，角色和责任，法律法规限制等）
- ◆ 对密码技术的应用，其关键在于密钥管理：
 - 生成，分发和传输
 - 使用和验证
 - 保存，消除和恢复
- ◆ 对正式上线的运营系统应严加控制，做好软件开发的变更控制和管理
- ◆ 不将运营系统上的敏感信息直接用作测试系统
- ◆ 需要对外包开发提高警惕（代码所属权，知识产权，资格认定，第三方保证，合同中对质量和安全功能的要求，中间审计，安装前测试）

系统开发安全性的重要提示

- ◆ 建立安全的软件开发过程和编码规范
- ◆ 开发一个有关如何利用加密控制对信息进行保护的策略（哪些信息要加密，加密的强度如何，移动介质或传输中的加密，密钥管理，角色和责任，法律法规限制等）
- ◆ 对密码技术的应用，其关键在于密钥管理：
 - 生成，分发和传输
 - 使用和验证
 - 保存，消除和恢复
- ◆ 对正式上线的运营系统应严加控制，做好软件开发的变更控制和管理
- ◆ 不将运营系统上的敏感信息直接用作测试系统
- ◆ 需要对外包开发提高警惕（代码所属权，知识产权，资格认定，第三方保证，合同中对质量和安全功能的要求，中间审计，安装前测试）

ISO27001:2013附录A解析



识别与外部伙伴相关的风险

- ◆ 外部伙伴可能包括：
 - 服务提供商（例如ISP、网络和通信服务、维护和支持服务提供商等），管理安全服务（MSS）
 - 客户
 - 外包服务（IT系统设施和运维、数据采集、呼叫中心）
 - 管理和业务咨询顾问、审计师
 - 软件产品和IT系统的开发者和供应商
 - 保洁快餐等外部服务
 - 临时工、短期兼职人员等
- ◆ 如果需要让外部伙伴访问组织的信息处理设施或信息，有必要先做一次风险评估，找到特别的安全控制需求。应该考虑到是物理访问，还是逻辑访问，是现场访问还是非现场访问。还应考虑需要访问哪些设施和信息？信息的价值，必要的控制，授权以及监督方式，出错可能造成的影响，对安全事件的响应，法律法规等。
- ◆ 在没有采取必要控制措施，包括签署相关协议之前，不应该授权给外部伙伴访问。应该让外部伙伴意识到其责任和必须遵守的规定。

在供方协议中体现安全

- ◆ 供方应学习和了解企业的信息安全方针和相关安全管理制度.
- ◆ 供方应意识到自身的信息安全责任,包括硬件和软件安装及维护的责任.
- ◆ 供方人员更换的管理
- ◆ 供方访问控制策略:
 - 允许的访问方法, 授权流程, 禁止声明
- ◆ 信息安全事件及问题处理机制
- ◆ 期望的SLA及监督报告机制
- ◆ 监督、撤销等权利, 审计责任约定
- ◆ 法律责任
- ◆ 知识产权保护
- ◆ 服务的中止或重新协商协议的条件
- ◆



ISO27001:2013附录A解析

A.16 信息安全事故管理

A.16.1 信息安全事件管理和持续改进

- A.16.1.1 职责和程序
- A.16.1.2 报告信息安全事态
- A.16.1.3 报告信息安全弱点
- A.16.1.4 信息安全事件的评估和决策
- A.16.1.5 信息安全事故的响应
- A.16.1.6 回顾信息安全事故
- A.16.1.7 收集证据

目标：确保一致和有效的方法来管理信息安全事件，包括通信安全事件和弱点的报告

司法取证

计算机取证(司法取证与调查分析)：

以司法可接受的方式识别、保留、分析和呈现数字证据,以支持必要的法律活动,有效应对电子犯罪和非法入侵.

证据链应包含以下信息:

- 谁曾经访问信息(按照时间顺序方式)?
- 按照怎样的程序管理证据(磁盘复制/虚拟内存转储)?
- 怎样证明证据保全的有效性(文档记录/校验/时间戳等控制)?

ISO27001:2013附录A解析

A.17 信息安全方面的业务连续性管理

A.17.1 信息安全连续性

A.17.1.1 规划信息安全连续性

A.17.1.2 实现信息安全的连续性

A.17.1.3 验证，评审和评估信息安全的连续性

目标：信息安全的连续性应嵌入组织的业务连续性管理（BCM），以确保任何时间都能保护信息并对不良事件进行预测

A.17.2 冗余

A.17.2.1 信息处理设施的可用性

目标：确保信息处理设施的可用性

关于BCP的重要提示

◆ 有效的业务连续性计划必须包括业务与技术两部分：

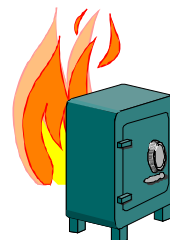
- 业务观点：行政主管必须定义和规划他们的可用性需求，以及达到这些需求所需动用的资源
- 技术观点：IT管理者必须定义、规划及设计一份业务连续性计划，以达到企业的可用性需求

◆ 灾难恢复的业务观点包括评估发生意外的可能性、风险变成事实后所带来的冲击、以及IT管理阶层的应对措施

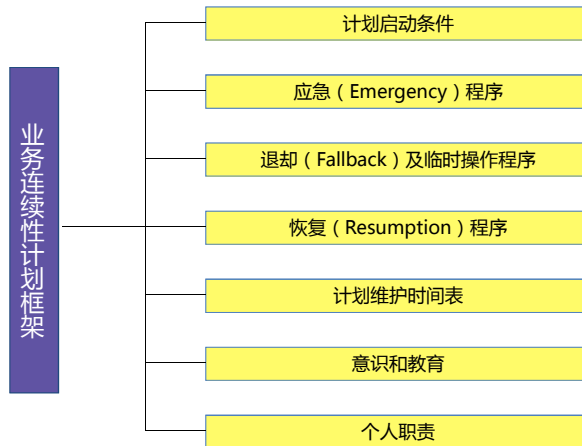
◆ 为了有效地对抗灾难，拟定业务需求时应注重于设计出在发生灾难时能够至少涵盖下列部分的完整计划：

- 响应：发生灾难时，必须立即采取的紧急应变措施
- 复原：为了从灾难中复原所采取的动作
- 继续：为了继续正常业务运作所采取的动作
- 还原：让原来的节点还原成最初状况的过程
- 责任：个人应对执行哪一部份的计划负责

◆ BCP负责人必须确认计划实施所需资源：人力、装备、技术、财务



关于BCP的重要提示



BCP测试方式

- ◆ 针对各种假想场景做桌面测试，展开讨论
- ◆ 模拟（特别针对承担事后/危机管理角色的人员培训）
- ◆ 技术恢复测试（确保信息系统能被有效恢复）
- ◆ 在替换场地做恢复测试
- ◆ 测试供应商设备和服务（确保所提供的外部服务和产品符合合同承诺）
- ◆ 排练（测试组织、人员、设备、设施和流程能够应付中断）

ISO27001:2013附录A解析

A.18 符合性

A.18.1符合法律和合同的要求

- A.18.1.1识别使用的法律和合同的要求
- A.18.1.2知识产权（IPR）
- A.18.1.3文档化信息的保护
- A.18.1.4隐私和个人信息的保护
- A.18.1.5加密控制措施的监管

目标：避免违反相关信息安全的法律，法规，规章，合同义务以及任何安全要求



A.18.2信息安全审查

- A.18.2.1信息安全的独立审查
- A.18.2.2符合安全政策和标准
- A.18.2.3技术符合性检查

目标：确保信息安全设施依照组织的策略和程序运行和实施



Q&A?

谢谢！